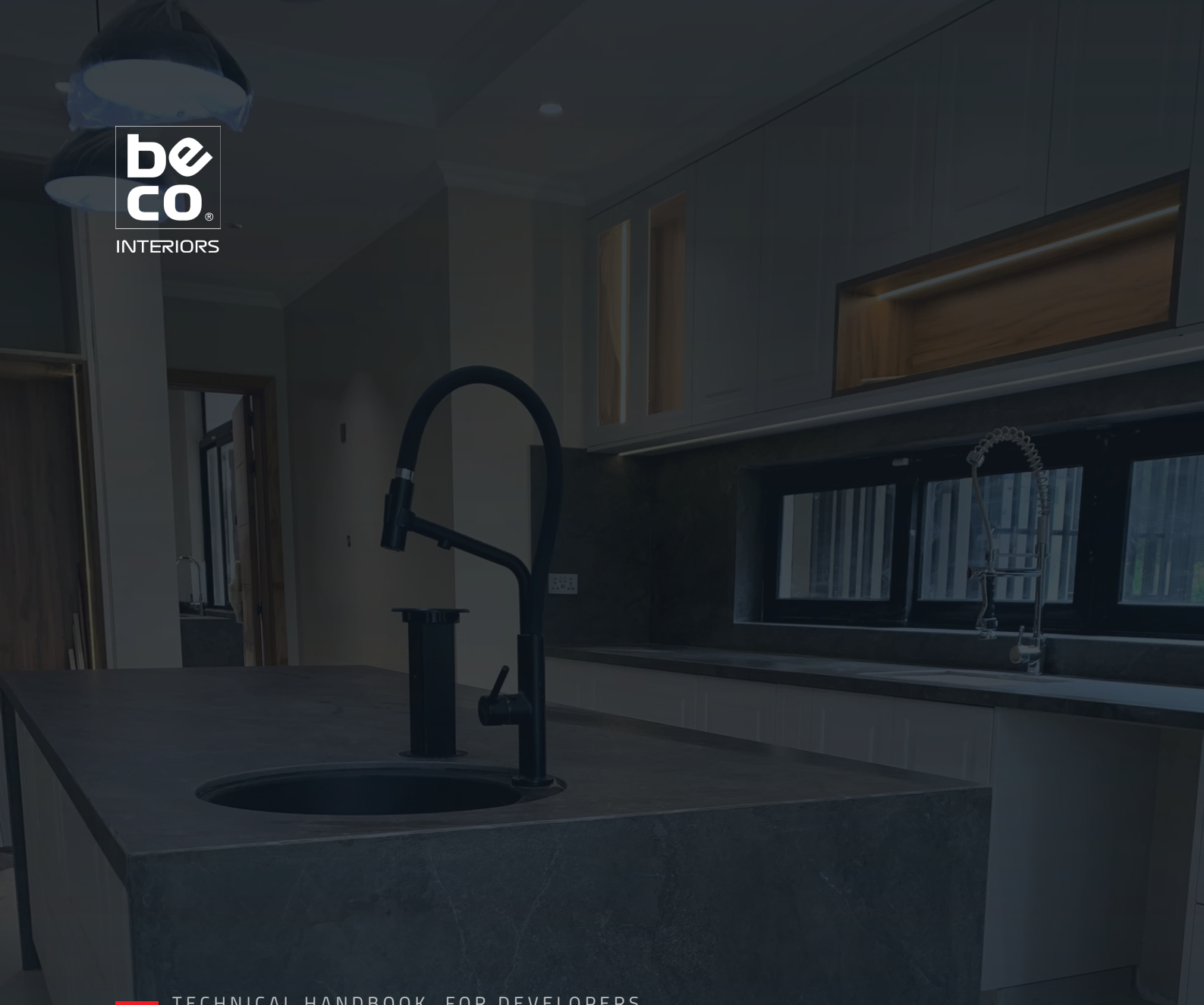


beco INTERIORS

TECHNICAL HANDBOOK, FOR DEVELOPERS

The Beco platform, from the inside

Architecture, data model, access control, the flows that matter, and how a change reaches production. Written so a developer new to the codebase can take it over.

PREPARED FOR	PREPARED BY	DATE	REFERENCE
Beco Interiors	Brightex Solutions	13 October 2026	BEC-2026-004, release 18

CONFIDENTIAL: PREPARED FOR BECO INTERIORS AND THE DEVELOPERS IT APPOINTS

00

START HERE

Contents

01 The platform at a glance
02 Architecture
03 Repository and stack
04 Routes
05 Data model
06 Access control
07 The flows that matter
08 Security
09 Environments and releases
10 Testing and quality gates
11 Accounts and ownership
12 Known gaps
13 Your first day
A Key decisions

> Beco sells interior materials through multi item quotations, not a checkout. Everything here serves one job: a salesperson raises, prices and issues a branded quote from a phone faster than writing it on paper.

Sources of truth. This handbook summarises the repository as released on 13 October 2026 (main at `65ac22d`, both databases at migration 71). Where it and the code disagree, the code wins. The committed docs in `docs/` go deeper: `DECISIONS.md` (why), `SCHEMA.md`, `SECURITY.md`, `DEPLOYMENT.md`, `RUNBOOK.md`, `HANDOVER.md`, `QA-CHECKLIST.md`. `CLAUDE.md` holds the project rules every change must keep.

01

OVERVIEW

The platform at a glance

2	22	71	3,300+
APPS, ONE MONOREPO	POSTGRES TABLES	MIGRATIONS APPLIED	AUTOMATED TESTS

PUBLIC

Storefront, www.beco.co.ke

Catalogue by range, product pages with price or price on request, a quote list kept in the browser, and a submission that becomes a quote in the database. Blog, gallery, team, contact. Statically generated and revalidated hourly or on demand.

STAFF

Dashboard, dashboard.beco.co.ke

Quotes (table and board), counter quotes on a phone, orders and receipts, customers, catalogue and photographs, announcements, reports, users and permissions, settings, audit. Studio (blog drafting) lives inside it, Brightex only.

Principles that shape every file

- **The database is the authority.** Row level security is deny by default on every table; changes to quote lines and statuses go through Postgres functions that enforce the business rules and an optimistic lock.
- **Checked in two places.** Route access is decided by one map (`apps/dashboard/src/lib/access.ts`) in the proxy and in every page and action, and again by RLS. Hiding a button is never access control.
- **Everything is tested.** Unit, component (jsdom), integration against a local Supabase, and pgTAP tests for every policy from every role. No browser automation in the suite; journeys are walked by hand against `docs/QA-CHECKLIST.md`.
- **Beco owns its accounts.** Data, DNS, images and email are on Beco's accounts; Brightex holds only the repository and the Vercel projects.
- **House rules enforced by CI:** no em dashes anywhere, no browser dialogs (`ConfirmDialog` and `toast()` instead), a 16px type floor, verified contrast.

02

HOW IT FITS TOGETHER

Architecture

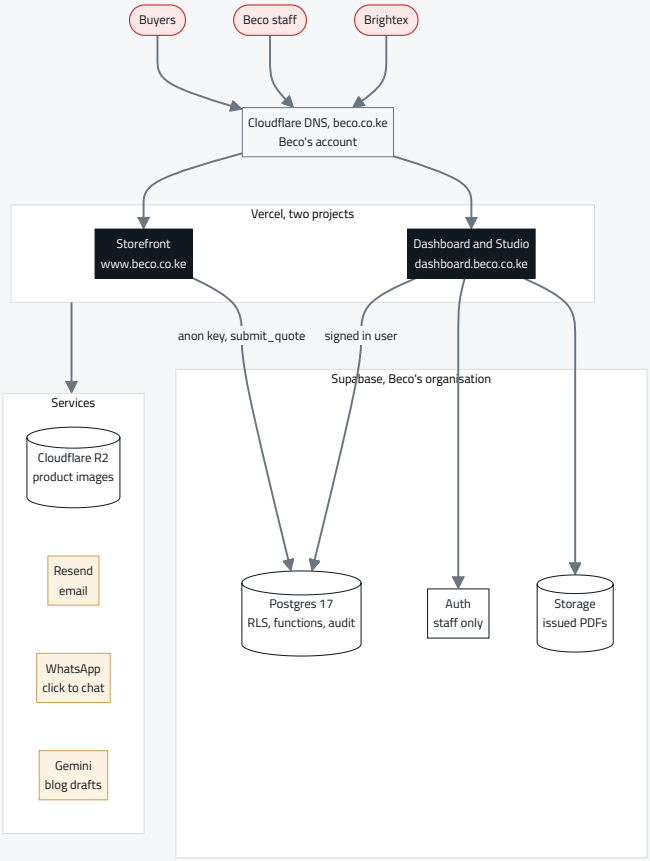


Figure 1. The layers. The storefront never holds a privileged key; the dashboard acts as the signed in person, so RLS applies to every staff read and write. Images reach the browser through the `/api/img` proxy; the Drive import runs in GitHub Actions and writes to R2 and Postgres directly.

The pieces, one line each

Piece	Role
Storefront	Next.js 16 App Router. Server rendered and statically generated from the database with the anonymous key. Writes only through the `submit_quote` function, rate limited at the action.
Dashboard	Next.js 16. Every page and server action resolves the session, checks `lib/access.ts`, validates with zod and calls Supabase as the signed in user. The admin surface (Geist, tighter scale) sits on the same `@beco/ui` components as the shop (D143).
Supabase	Postgres 17 with RLS on all 22 tables, security definer functions for every commercial write, audit triggers, Auth for staff (no public signup), Storage for issued PDFs, Realtime for the new quote banner.

Cloudflare R2	Product and blog images. Originals are processed once into WebP at 400, 800 and 1600 wide plus a blur placeholder. Served through the `/api/img` proxy route today; `img.beco.co.ke` is planned but does not resolve yet.
Resend	Quote and receipt emails from `quotes@beco.co.ke`, and the buyer's confirmation after a website request.
GitHub Actions	CI on every pull request, and the Drive import (long sharp and HEIC jobs that cannot run on Vercel).
Gemini	Drafts blog posts in Studio from a brief; a validator and a person check every draft before it is published.

03

WHERE THINGS LIVE

Repository and stack

Repository `brightexsolutions/beco-interiors`, private. `main` is what is live; `dev` is the standing branch kept ahead of it; feature branches fork from `dev`.

Path	Purpose
apps/storefront	The public site. Anonymous key only.
apps/dashboard	Operations and Studio. Next.js middleware is named `proxy.ts` in this Next version.
packages/ui	`@beco/ui`: tokens, primitives, Dialog, Sheet, ConfirmDialog, toast, DataTable, charts, SegmentedControl, Portal. If a pattern appears twice it belongs here (rule 5).
packages/documents	Quote, receipt and report PDFs with `@react-pdf/renderer`; email templates; sending through Resend.
packages/validation	zod schemas for every form, the in-memory rate limiter, `safeReturnPath`, constant time bearer checks, upload limits.
packages/supabase-client	Browser, server and admin clients. The admin (service role) client is server only.
packages/types	Database types (`pnpm db:types`) and enums such as `DASHBOARD_MODULES`.
tools/drive-import	The Drive to R2 catalogue importer, run in GitHub Actions or by hand (`pnpm drive:import`).
tools/setup, tools/backup	Env linking on install, the type floor check, the secret scan and the CSP test.
supabase/	70 migration files (01 to 71, no 29), 47 pgTAP test files, `seed.sql` with fictional data only.
docs/	Committed documentation. `files/` and `_incoming/` are gitignored internal material.

Stack

Layer	Choice and version
Runtime and tooling	Node 22, pnpm 11.24, Turborepo 2.10, TypeScript 7 (strict, `exactOptionalPropertyTypes`)
Framework	Next.js 16.3 App Router, React 19.2, server actions
Styling	Tailwind 4.3 with tokens in `packages/ui/src/tokens/tokens.css`; Titillium Web and Cormorant Garamond self hosted on the shop, Geist on the dashboard
Database and auth	Supabase: Postgres 17, Auth, Storage, Realtime; supabase-js 2.112, @supabase/ssr 0.12
Validation	zod 4.5 on every server action
Images	sharp 0.35 for derivatives; `heic-to` (libheif in WebAssembly) decodes iPhone photos in the browser; AWS S3 SDK against R2
Documents and email	@react-pdf/renderer 4.9; Resend
Charts and feedback	Recharts 2.15 inside @beco/ui; sonner toasts
Testing	Vitest 4.1, React Testing Library 16, jsdom 25, vitest-axe, pgTAP
Analytics	GA4 (production only), Vercel Analytics on the storefront, first party `analytics_events` table

04

SCREENS AND ENDPOINTS

Routes

Storefront

Route	Purpose
/	Home: photography led hero, ranges, the slab to surface scroll
/shop, /shop/all, /shop/[category]	Browse by range; every product; a range page (an old slug answers with a 301)
/product/[slug]	Product: price or price on request, sizes with their own prices, add to quote
/quote	Review the quote list (browser storage `beco_quote_cart_v1`) and submit
/about, /gallery, /team, /contact	Company pages; /team lists staff flagged public
/blog, /blog/[slug]	Articles written in Studio

/privacy, /terms	Dated legal pages
/og/*	Generated link preview images
/api/health, /api/img, /api/revalidate	Uptime probe; R2 image proxy; on demand revalidation behind a bearer secret
robots.ts, sitemap.ts	Generated from the database

Dashboard

Route	Purpose
/login, /change-password	Sign in; forced password change on first sign in
/	Home: what needs attention, the month in figures, charts, team, catalogue
/quotes	Table or board (`?view=board`), with filters by owner, status, source
/quotes/new	A counter quote on a phone
/quotes/[reference], /pdf	Quote detail: lines, approval, status, PDF, email, WhatsApp, convert to order
/orders, /orders/[reference], /pdf	Orders, payment, receipt
/customers, /customers/[id]	One record per client, keyed on phone
/products, /products/import	Catalogue as list or cards with the editor in a sheet; Drive import (Brightex only)
/announcements, /reports, /leaderboard	Announcement bar; reports and the sales review PDF; the team
/users, /settings, /audit	Accounts, grants and module access; business settings; the audit log
/studio/blog	Blog drafting with Gemini, Brightex plus allowlist
/launch	Anniversary launch switch, Brightex only
/api/ops-alert, /api/quote-confirmation	Failure alerts to Brightex; the buyer's confirmation email for the storefront

05

POSTGRES

Data model

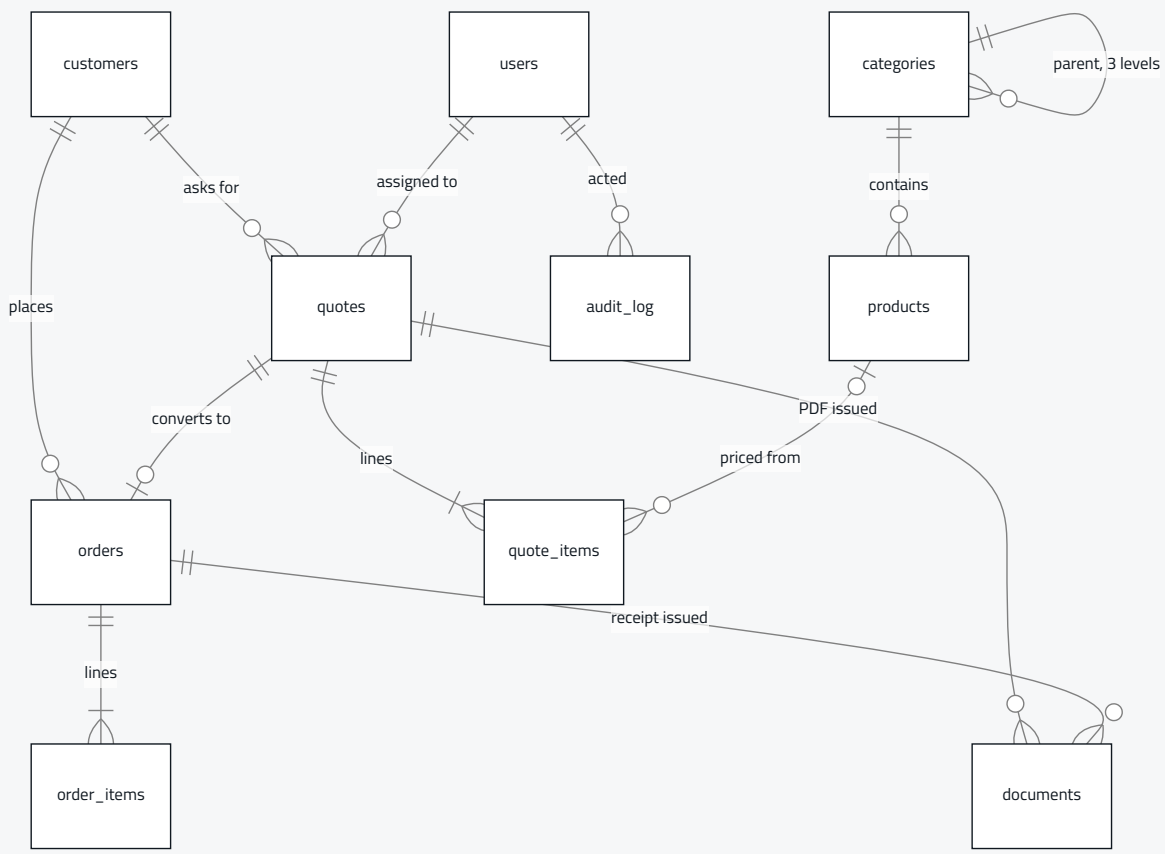


Figure 2. The commercial core. Audit triggers write every change to these tables into `audit_log`.

Table	Purpose and notes
users	Profile beside `auth.users`: role, active flag, forced password change, /team fields, grants, `module_grants`. Deactivated, never deleted.
categories	Self referencing tree, at most three levels, identity is the Drive `source_path`.
products	Price (null for price on request), display mode, availability, images with shot roles, specs, `sizes` (label, price, code), stock and low stock mark. Soft deleted.
customers	One live record per phone (`phone_key`), KRA PIN, notes.
quotes	`BEC-Q-00042`. Status new, reviewing, quoted, won, lost; source web, walk in, phone, WhatsApp; owner and assignee; money; approval; `updated_at` is the lock; `requested_items` keeps what the buyer asked for.
quote_items, order_items	Lines with a description snapshot, `list_price` beside `unit_price`, generated `line_total`. Custom lines have no product.

orders	`BEC-O-00042`, one live order per quote, status pending to fulfilled or cancelled, paid flag with `paid_at`.
documents	One row per issued PDF, quote or receipt, with where and how it was sent.
audit_log	Who, what, before and after. Written only by triggers and sign in.
settings	Key and value: VAT, validity, payment channels, WhatsApp number, business identity, Brightex allowlist, launch switch.
Others	blog_posts, announcements, testimonials, clients, analytics_events, category_slugs and product_slugs (301s), import_files, import_runs, import_issues, import_state.

Functions that carry the business rules

- `submit_quote`: the only public write. Recomputes prices from the catalogue, links or creates the customer, in one transaction.
- `create_counter_quote`, `add_catalogue_quote_lines` (one lock, takes a size), `add_custom_quote_line`, `update_quote_lines`, `remove_quote_line`: every line change, guarded by `assert_quote_lines_open` so a won, lost or converted quote cannot change.
- `set_quote_status`: forward only, lost needs a reason, won and lost are closed; `reopen_quote` is the only way back from lost.
- `refresh_quote_money`, `refresh_order_money`: totals by trigger. Prices include VAT and the documents back it out (D50).
- `convert_quote_to_order`, `set_order_status`, `mark_order_paid`.
- Access helpers: `current_user_role()` (null when inactive), `is_admin()`, `is_brightex_user()`, `has_module()`, `can_grant_module()`, `has_staff_manage()`.
- A stale lock raises SQLSTATE `PT409` everywhere; the UI turns it into "This quote changed while you were editing".

06

WHO CAN DO WHAT

Access control

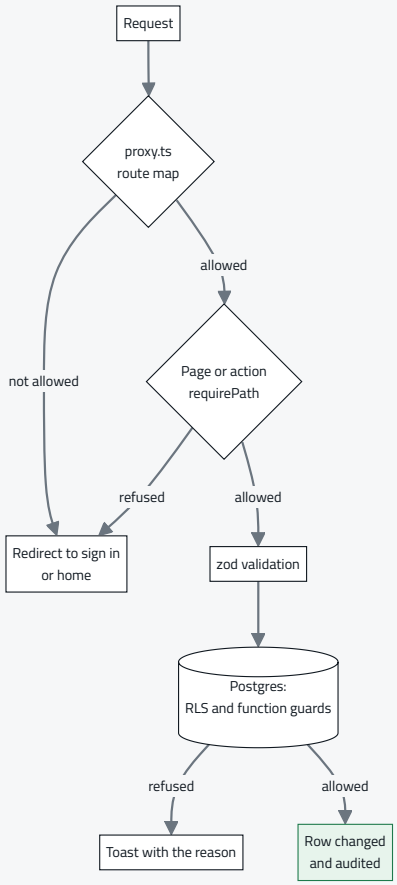


Figure 3. Every write passes three gates. The route map in `lib/access.ts` is read by the proxy, the navigation, the guide and the actions alike; Postgres is the authority.

Role	Can	Cannot
beco_sales	Raise, price and issue quotes; claim unassigned ones; move, reopen and convert their own; record payment; add and edit customers.	Approve, reassign, cancel an order, delete a customer.
beco_product_manager	Products, ranges, photographs, stock; read customers.	Quotes and orders (unless granted to read).
beco_editor	Reads the published catalogue.	Any operations screen.
beco_admin	Everything sales can, on every quote; approve prices away from the catalogue; reassign; cancel orders; announcements, reports, settings.	Brightex accounts, the import, Studio.
brightex_admin	All of the above, accounts, the allowlist, the Drive import, Studio (with the allowlist), the launch switch, every grant.	

Grants on a person, beside the role

- **Module grants** (D136, migration 70): `module_grants` opens a section to read: quotes, orders, customers, products, announcements, reports, users, settings, audit. Writes never widen; the shell shows a View only pill. Brightex grants anything; a staff manager only what they reach, on a Beco account, never their own.
- **Staff management** (`can_manage_users` , D135): opens /users for Beco accounts.
- **Audit read** (`can_read_audit`).
- The `guard_users_staff` trigger refuses any grant change the rules do not allow, before RLS and before the check constraint.

07

STEP BY STEP

The flows that matter

A quote's life

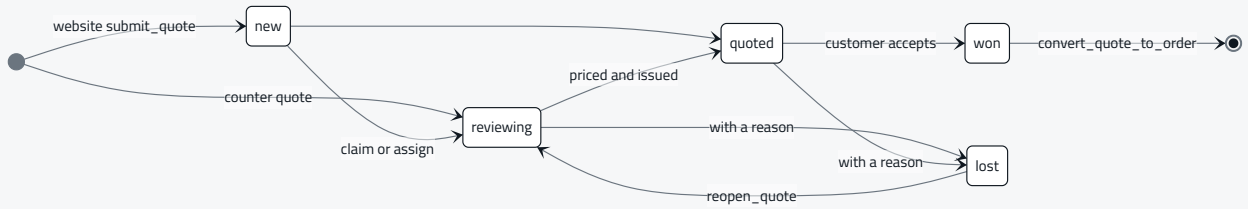
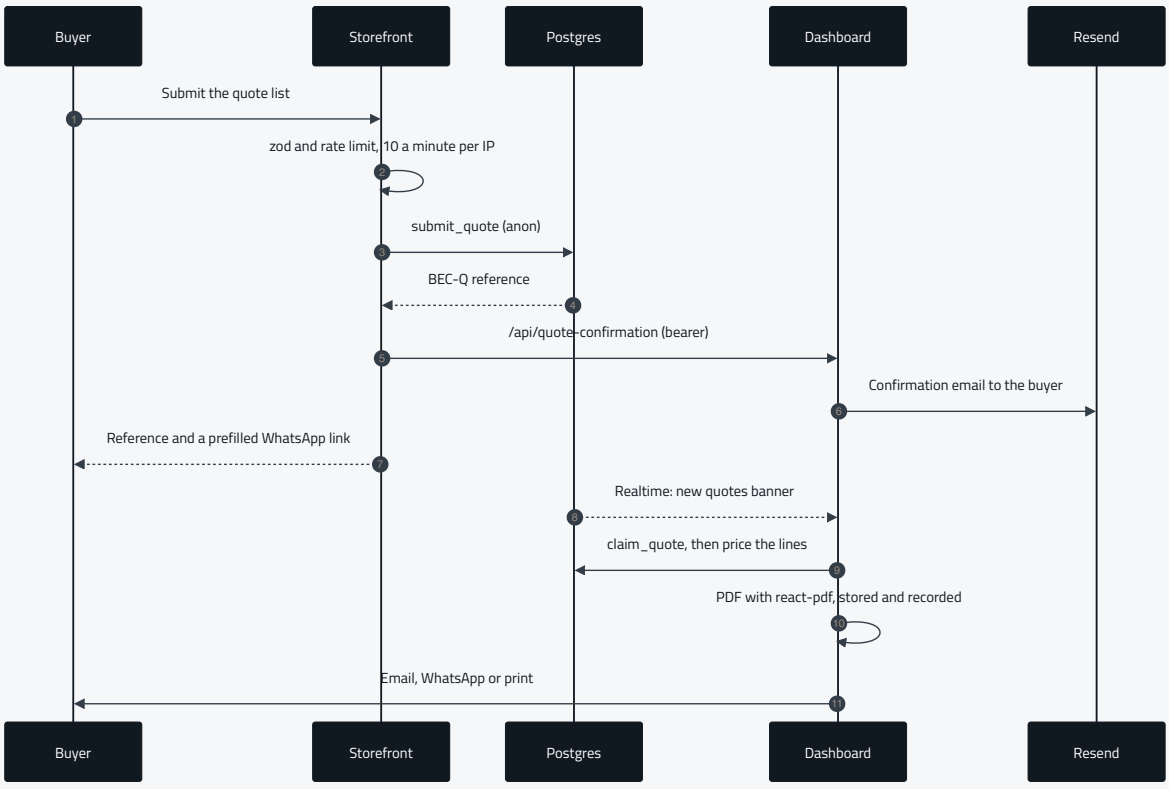


Figure 4. The moves `set_quote_status` allows. A quote priced away from the catalogue cannot reach quoted, won or lost until an admin approves (a check constraint, D86). The board (D148) offers exactly these moves through `lib/quote-transitions.ts`, which the detail screen reads too.

Website request to a priced quote



Product photographs

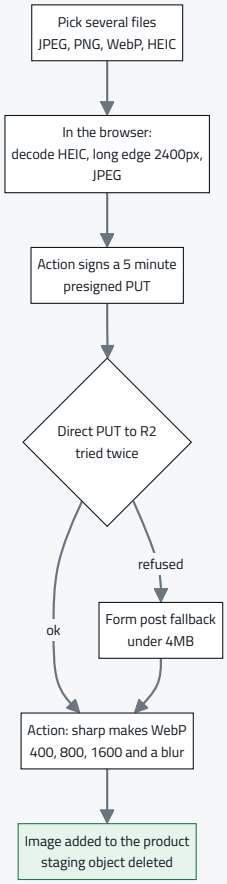


Figure 5. D116 and D139. The browser's CSP must name the account's R2 host for the direct PUT: built at build time, so `R2_ACCOUNT_ID` must be readable then (D150). R2 CORS and lifecycle rules are still to be configured.

The other flows, briefly

- **Counter quote.** `/quotes/new` on a phone: customer, lines from the catalogue (one row per size) or custom, any price typed with the list price kept beside it. A line priced away from the catalogue sets `requires_approval`; any later line change clears the approval.
- **Won to paid.** `convert_quote_to_order` copies the prices; the order moves to confirmed and fulfilled; `mark_order_paid` stamps the date; the receipt PDF comes from the order. Stock is not decremented automatically.
- **Drive import.** Brightex starts it from /products/import, which dispatches `drive-import.yml`; the job reads the Drive tree, plans by md5, uploads derivatives to R2 and upserts by `source_path`, never overwriting prices Beco has set. Needs `GITHUB_ACTIONS_TOKEN`, not yet set.
- **Blog.** Studio sends a brief to Gemini, a validator rejects em dashes, banned phrases and long meta, a person edits and checks the claims, the cover needs alt text, publishing revalidates the blog and sitemap.
- **Announcement bar.** Admins schedule it; the shop renders the live one with the highest priority server side, height reserved.

08

DEFENCE IN DEPTH

Security

HEADERS

An explicit policy on both apps

CSP with `default-src 'self'`, `frame-ancestors 'none'`, `object-src 'none'`, `upgrade-insecure-requests`; HSTS a year; X-Frame-Options DENY; nosniff; strict referrer; camera, microphone and location denied. The dashboard adds `'wasm-unsafe-eval'` for the HEIC decoder and `noindex`. `'unsafe-inline'` scripts remain a known compromise.

INPUT

Validated on the server

zod on every action; client checks are for convenience only. Safe return paths, constant time secret comparison.

SECRETS

Service role stays on the server

Used only for account creation and the import job. Never in a `NEXT_PUBLIC_` variable; CI's secret scan fails the build if it leaks.

ACCOUNTS

Staff only, no public signup

Supabase Auth; forced password change on first sign in; deactivation makes the role null so RLS closes and sessions end. No MFA yet (deferred, D83).

Rate limit (in memory, per instance)	Limit
Website quote submission	10 a minute per IP (documents say 5; the code is the truth)
Dashboard sign in	10 a minute per address
Drive import dispatch	1 a minute per person
/api/ops-alert, /api/quote-confirmation	60 a minute each

The in memory limiter is a brake, not a wall. A Cloudflare edge rule on POST to the quote and contact endpoints is the intended backstop and should be confirmed.

Soft delete and audit. Products, quotes, orders and customers carry `deleted_at`; users are deactivated. Audit triggers record every change to commercial tables with who and before and after.

09

GETTING CHANGES LIVE

Environments and releases

Environment	Database	Notes
Local	`supabase start` (Docker), seeded from `seed.sql`	Fictional staff, password `beco-dev-pass`. Storefront :3000, dashboard :3001. Point `R2_ENDPOINT` at a local S3 stand in to exercise uploads.
Staging	`beco-staging` (lzsqfsnjijpqnjukqpnu)	Vercel Preview deployments. Fictional data only, never cloned from production. `staging.beco.co.ke` is not yet in DNS; the dashboard Preview lacks its R2 keys.
Production	`beco-prod` (fctfpttoinhsncakhirh)	www.beco.co.ke and dashboard.beco.co.ke. Real names and phone numbers: nothing tests against it.

How a release is done today

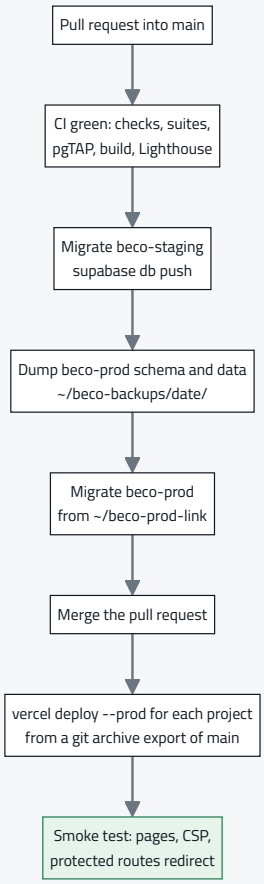


Figure 6. Migrations always run before the deploy that needs them and are kept additive, so the code already live keeps working in between. Deploy from an export, never the working tree: `.claude/` holds large agent worktrees that `.vercelignore` does not list.

- **Planned, not yet working:** `deploy-production.yml` (staging migrate, approval, production) needs the Supabase secrets in GitHub and required reviewers on the Production environment.
- **Rollback.** Code: promote the previous Vercel deployment, seconds. Database: forward only; reverse with a new migration, with the dump as the floor. If both, roll the code back first.
- **Backups.** Manual dumps before every production migration. The nightly encrypted backup to Drive in the plan is not yet built, and no restore drill is recorded.
- **Health.** `/api/health` on both apps; failures email Brightex through `/api/ops-alert`. Keep alive and uptime monitors are planned on cron-job.org and UptimeRobot.

10

WHAT GREEN MEANS

Testing and quality gates

551	911	1,138	719
UNIT TESTS	COMPONENT TESTS	DASHBOARD TESTS	PGTAP ASSERTIONS

Plus 63 integration tests against a local Supabase. Counts as of the 13 October release.

CI check (ci.yml)	What it protects
AGENTS.md symlink	Claude Code and Codex read the same rules
Em dash grep	House style in code, copy, documents and commits
Browser dialog grep	No `window.confirm`, `alert` or `prompt`
Secret scan	The service role key never ships
Type floor, contrast	16px minimum type; every colour pair passes AA
Typecheck, unit, component, dashboard	Behaviour, accessibility (axe), the controls doing what they say
pgTAP, integration	Every RLS policy from every role, every function's refusals
Build and serve	Both apps build; the storefront serves with no console errors and a production CSP
Lighthouse	CLS and blocking time as errors; LCP and page weight as warnings in CI

Commits are checked by `.githooks/commit-msg` (activate with `git config core.hooksPath .githooks`): no em dashes, no agent attribution. Every interactive control is listed in `docs/QA-CHECKLIST.md` with how it was proven to work.

11

WHO HOLDS WHAT

Accounts and ownership

Account	Owner	Notes
Domain beco.co.ke	Beco	Registrar is Beco's
Supabase organisation	Beco	Both projects; Brightex is a member
Cloudflare zone and R2	Beco	Under becointeriorsdev@gmail.com
Resend	Beco	Sending domain beco.co.ke
Monitoring, keep alive	Beco	cron-job.org, UptimeRobot
Google Analytics, Search Console, Business Profile	Beco's Google account	Brightex as manager only
Drive service account	Beco	beco-import@beco-platform.iam.gserviceaccount.com
GitHub repository	Brightex	brightexsolutions/beco-interiors
Vercel projects	Brightex	beco-interiors, beco-dashboard
Gemini key	Brightex	Studio drafting only

If Brightex stops. The site, database, images, email and DNS keep running with no action; only new deployments stop. `docs/HANDOVER.md` lists the thirteen steps to move the repository and Vercel projects to Beco, rotate credentials and remove Brightex's access, and a one hour emergency path Beco can run alone.

12

HONEST LIST

Known gaps

Area	Open item
Releases	GitHub lacks the Supabase secrets and Production reviewers, so the Actions deploy cannot migrate; releases are manual (section 09).
Staging	`staging.beco.co.ke` not in DNS; dashboard Preview lacks R2 keys; staging needs a reseed.
Images	R2 CORS and lifecycle rules; `img.beco.co.ke`; `R2_ACCOUNT_ID` as a plain variable (D150).
Import	`GITHUB_ACTIONS_TOKEN` not set, so the dashboard has never dispatched an import.

Resilience	Nightly backup workflow not built; `backup:verify` script missing; no restore drill recorded; monitors to confirm.
Security	No MFA; `'unsafe-inline'` scripts; in memory rate limiting; Cloudflare edge rule to confirm; check production for anonymous orders before migration 63.
Product	An end to end production quote with its email; real phone QA including the board's press and hold; Search Console under Beco's account.
Docs drift	`SYSTEM.md` (pdf-lib, Actions only deploys), `SCHEMA.md` RLS table, Studio path in `CLAUDE.md` and `HANDOVER.md`, `STATUS.md` dates.

13

ONBOARDING

Your first day

```
git clone git@github.com:brightexsolutions/beco-interiors.git
cd beco-interiors
git config core.hooksPath .githooks
pnpm install --frozen-lockfile        # links .env.local into both apps
supabase start                        # Docker; local Postgres, Auth, Storage
supabase db reset                     # migrations 01 to 71 and the fictional seed
pnpm --filter @beco/dashboard dev     # http://localhost:3001, sign in with a seeded account
pnpm --filter @beco/storefront dev    # http://localhost:3000
```

```
pnpm typecheck
pnpm test:unit && pnpm test:component && pnpm test:dashboard
supabase test db                      # pgTAP, every policy from every role
pnpm test:integration                 # needs the local stack
pnpm build
```

- Read `CLAUDE.md` first: its rules are enforced by CI and by review.
- A database change is one migration with its RLS policies and pgTAP tests in the same change (`supabase-migration` and `rls-policy` skills in `.claude/skills`).
- A UI change uses `@beco/ui` tokens, keeps 44px targets and the 16px floor, and adds its controls to `docs/QA-CHECKLIST.md`.
- Record the why of a non obvious change as the next D number in `docs/DECISIONS.md`.
- Ask Brightex for: membership of the Supabase organisation, Cloudflare and Resend; the Vercel team; the `files/BUILD-PLAN.md` reference.

A

WHY IT IS BUILT THIS WAY

Key decisions

D	Decision	Reason
D1	Quotes and orders, no checkout or online payment	Beco sells through multi item quotations; nobody pays online
D8	Payment is a flag with a date	Payment happens offline; reports keep invoiced and collected apart
D86	Any price can be typed; off catalogue needs an admin's approval	Speed at the counter with one person overseeing discounts
D10, D19	Beco owns every account but the repository and Vercel	The business survives Brightex disappearing
D13, D16	Cloudflare R2 for images, processed once	No egress fees; cost grows with the catalogue, not the traffic
D44	Separate staging and production databases	Nothing tests against real customers' data
D26, D39	Quote request first, WhatsApp second, call third	One clear path to conversion on every page
D50	Prices include VAT	Adding it on top would overstate every quote by 16%
D105, D115	Drive import in GitHub Actions, Brightex only	Long jobs and the service key cannot live on Vercel
D116, D139	Photos resized on the device, sent straight to R2	Mobile data and Vercel's request limit
D127	Production moved to its own database	Production had been running on staging
D130	Real customer records	Returning clients were guessed from phone numbers
D136	Read only module grants per person	Let someone see a section without inventing roles
D148	Quotes board beside the table	See the pipeline by stage; moves follow the database rules
D150	R2 host in the CSP only from a real account ID	A masked value would break direct uploads silently

The full list, D1 to D151, is in `docs/DECISIONS.md`, with the earliest decisions summarised in `files/BUILD-PLAN.md`.